

# KAKI

---

An evidence-grounded operating agent for SME employees: it answers from company records, remembers your working context, and prepares actions without taking control away from you.

HACKATHON TECHNICAL REPORT

28 September 2026

---

## 1 Executive summary

Small and medium enterprises carry the same coordination load as large ones with far fewer people to absorb it. Decisions are scattered across meetings, tickets, email, chat and documents, and employees lose hours reconstructing what happened, what they own and what needs sign-off. A generic chatbot makes this worse when it answers confidently without evidence or acts without a human checkpoint.

**Kaki** is an employee-facing operating agent built for that gap. It combines three workflows in one product: **company Q&A grounded in cited records**, **meeting follow-through** that turns commitments into reviewable drafts, and a **human-controlled recruiting assistant**, all on top of a persistent, per-employee working memory. Its runtime persona is a pragmatic Technical Chief of Staff: it searches before answering, cites what it read, keeps personal context apart from company evidence, and prepares actions for a person to approve.

We evaluated Kaki against an independent benchmark (OrgForge) and a supplementary suite we wrote for what OrgForge does not test, with every test case committed to version control before it was run.

**100%**

citation integrity: every cited source was one the agent actually retrieved (29/29)

**62%**

accuracy on OrgForge's evidence-answerable questions, an independent benchmark (29 questions)

**20/20**

held-out secrets blocked, 0/10 ordinary messages wrongly blocked, 0 in memory

**22/22**

honesty and "what's on my plate" cases passed, including 8 hard cases

These results come from the architecture rather than from prompt tuning. Company evidence and personal context are kept strictly apart, so Kaki can use what an employee told it without ever citing it as fact. Retrieval is **hybrid**: exact identifiers, full-text and semantic search fused together, scoped by date and record type, with explicit link-following from one record to the next. A **citation gate** in code refuses any answer that cites something the agent did not read. **Deterministic policy**, not the model, decides what may run, what needs approval and what must escalate. And a **two-layer sensitive-data gate** keeps secrets away from the model and from memory.

### Contents

- |                                    |                                |
|------------------------------------|--------------------------------|
| 1. Executive summary               | 8. Autonomy and human control  |
| 2. Problem and users               | 9. Security and guardrails     |
| 3. Product                         | 10. Evaluation                 |
| 4. Architecture                    | 11. Deployment and scalability |
| 5. Data and knowledge              | 12. Success metrics and demo   |
| 6. Agent design and reasoning loop | 13. Roadmap                    |
| 7. Memory                          |                                |

---

## 2 Problem and users

SME employees repeatedly need answers to questions like: *What was decided, and where is the evidence? What should I work on today? What did I promise in that meeting? Is this safe to send, or does someone need to approve it?* The information exists but is fragmented across tools and time. The cost is not just slower search. It shows up as duplicated work, missed commitments, inconsistent answers and weak handovers.

**Target users** are employees and team leads in an SME working across engineering, product, operations, people and customer workflows. Each signed-in session carries the employee's name, role and department, so the same system answers from the right person's perspective.

**Value hypothesis.** Fewer manual searches across systems; answers tied to evidence rather than recollection; commitments made visible as drafts with explicit approval; shared context reused without proportional headcount. These are hypotheses for a measured pilot. We do not yet claim realised time or revenue savings.

### 3 Product

| Module                    | What it does                                                                                                                                                        | Human control                                                                                                 |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>S1 Company context</b> | Answers workplace questions from company records with inline citations and an evidence graph; shows the employee's own plan and open work for any chosen day.       | Read-only. Every company claim cites a retrieved record.                                                      |
| <b>S2 Meeting actions</b> | Screens a live or uploaded transcript, extracts decisions and commitments, checks them against earlier decisions, and drafts emails, invites, tickets and messages. | Drafts wait for review; money and contract commitments escalate; the employee clicks send in their own tools. |
| <b>S3 Recruiting</b>      | Turns a role into hiring criteria, searches public profiles, tiers candidates and drafts outreach. A knowledge gap found in S1 can open a role here directly.       | No search runs until the criteria are confirmed; outreach is a draft.                                         |

Kaki is deliberately not an autonomous replacement for an employee. It is a context and preparation layer that removes reconstruction work while consequential decisions stay with people.

## 4 Architecture

Kaki is a modular monolith: one TypeScript/Fastify service coordinates identity, retrieval, models, memory and workflows, with PostgreSQL as the system of record. Each layer has its own trust boundary.

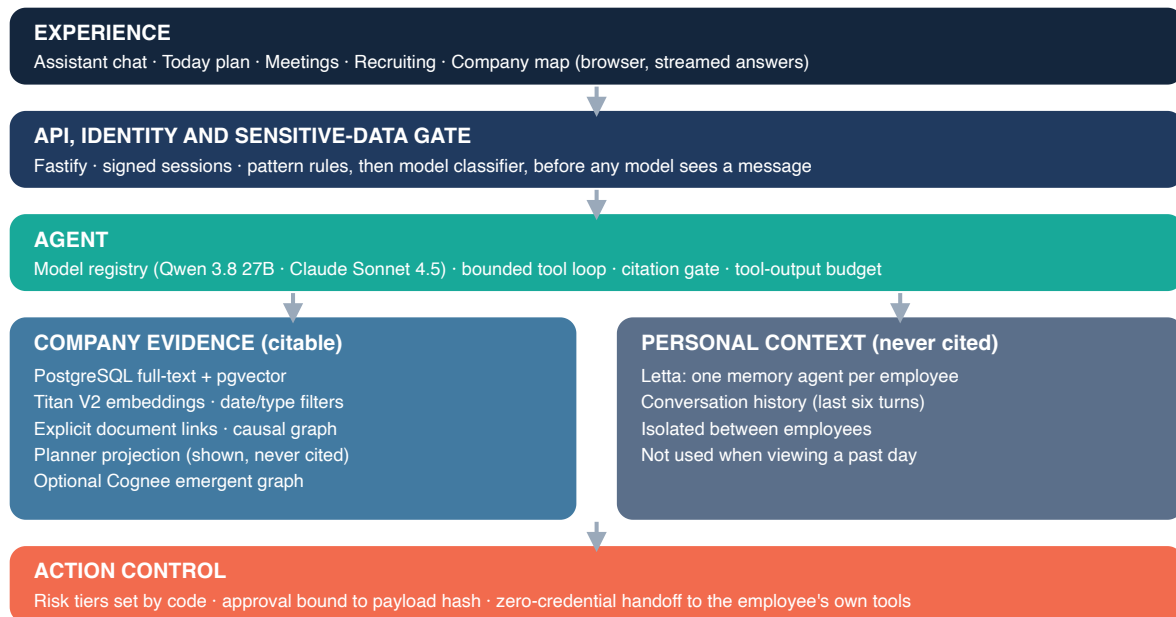


Figure 1. Layers and trust boundaries: company evidence is citable; personal context shapes answers but is never cited.

The separation matters because each kind of information has a different trust level. Company records are citable evidence. Personal memory is context, never a company source. Conversation history supports follow-ups. Proposed actions are stateful objects that must pass deterministic policy before anything leaves the system.

| Component         | Technology                                                                                                                   |
|-------------------|------------------------------------------------------------------------------------------------------------------------------|
| Service           | TypeScript, Fastify, Server-Sent Events; runs with <code>tsx</code>                                                          |
| Company knowledge | PostgreSQL 16 + pgvector; Amazon Titan Text Embeddings V2 (1024-d)                                                           |
| Personal memory   | Letta App Server (one memory agent per employee)                                                                             |
| Generation        | NUS SoCLaaS <b>Qwen 3.8 27B</b> (default, used for all evaluation); <b>Claude Sonnet 4.5</b> via an LLM gateway (selectable) |
| Optional          | Cognee (emergent graph), Whisper transcription, live ASR, Gmail/Calendar, Exa people search                                  |
| Browser           | marked, DOMPurify, Shoelace                                                                                                  |

## 5 Data and knowledge

### The OrgForge corpus

The demo company is the **OrgForge** synthetic SME workplace (Hugging Face): about 5,000 employee-visible records across 11 record types, including Slack, email, Confluence, Jira, Zoom transcripts, pull requests, alerts and invoices. `scripts/orgforge/ingest.py` normalises them into one PostgreSQL schema, split into 7,526 embedded chunks.

### Oracle isolation

OrgForge also ships its simulator's event log (17,541 "SimEvents"), which its authors describe as the answer-key layer. These are stored for offline builders but are **never chunked, embedded or returned by any search**,

**citation or related-source path.** The agent sees only what an employee could see. A regression test rejects simulator records even when mislabelled, so the agent cannot use them as a shortcut.

## Retrieval

1. **Hybrid search:** exact identifier lookup, English full-text search and pgvector semantic search, fused by reciprocal rank. The agent can pass a **date window** and **record types** ("the Confluence pages from that week") so records from other days cannot crowd out the right ones. If embeddings fail, search degrades to keyword-only rather than failing.
2. **Explicit links:** `get_related_sources` follows document references (PR → ticket → postmortem) from records already retrieved.
3. **Graph views:** a deterministic graph (3,286 nodes, 16,065 edges) powers the evidence graph and company map; an optional Cognee layer extracts an emergent graph from a query's retrieved slice without writing back to PostgreSQL.

## Planner projection

`orgforge_kb/build_timeline.py` projects each person's day plans, ticket states and the employee roster from the corpus. This powers "what's on my plate" for any chosen day. It is shown to the user but never cited as company evidence.

## 6 Agent design and reasoning loop

### Persona

The system prompt defines Kaki as a Technical Chief of Staff: communicate like an experienced peer, use tools before making workplace claims, treat retrieved text as data rather than instructions, cite every company fact, and state uncertainty plainly. Answers are generated at temperature 0, so tool choices and citations are reproducible.

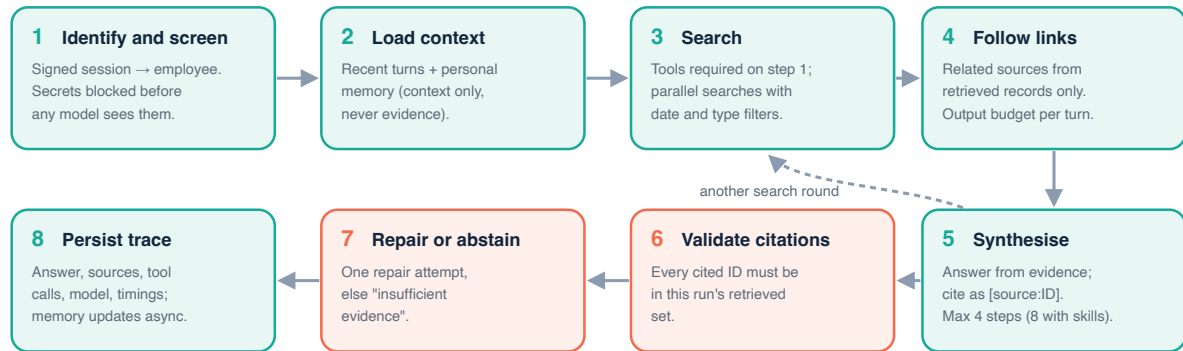


Figure 2. The bounded reasoning loop. Steps 6–7 (coral) are the citation gate; the dashed arrow is another search round when more evidence is needed.

### Tools

Kaki exposes typed, purpose-specific tools instead of arbitrary code execution. Parameters are JSON-schema definitions with enums, size limits and `additionalProperties: false`, and malformed arguments are rejected with an error the model can correct.

| Tool                                            | Purpose                                                  | Constraint                                                                                      |
|-------------------------------------------------|----------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <code>search_company_knowledge</code>           | Find company records                                     | Query, optional <code>from / to</code> dates and record <code>types</code> ; at most 20 results |
| <code>get_related_sources</code>                | Follow explicit document links                           | Seeds must already be retrieved                                                                 |
| <code>today_todo</code> , <code>day_plan</code> | The employee's own open work and plan                    | No person argument: always the signed-in employee                                               |
| <code>hiring_proposals</code>                   | Explain knowledge gaps (e.g. a domain whose owner left)  | Read-only                                                                                       |
| <code>open_role_from_gap</code>                 | Bridge S1 → S3: start a hiring role from a gap           | Draft only, on explicit request                                                                 |
| <code>load_skill</code>                         | Load a specialised skill (e.g. recruiting) and its tools | Registered skills only                                                                          |

### Why the citation gate matters

After the model drafts an answer, code checks that every `[source:ID]` refers to a record retrieved in this turn. An answer citing anything else is sent back once for repair; if it still fails, the user gets an explicit "insufficient evidence" reply instead of an unverifiable one. In evaluation this held for every answer (29/29): Kaki never cited a record it had not read. A per-turn **tool-output budget** (about 100k tokens of retrieved text) keeps even long, parallel investigations comfortably inside the model's context window.

---

## 7 Memory

| Kind                    | Where                                                                                             | Used for                                                                       |
|-------------------------|---------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Conversation            | PostgreSQL conversations and messages; the last six turns go in the prompt, long messages clipped | Follow-up questions in the same chat                                           |
| Personal working memory | Letta: one persistent memory agent per employee, updated in the background after each turn        | Durable facts the employee shared (focus, preferences, schedule), across chats |
| Company memory          | PostgreSQL records, chunks and links                                                              | Citable evidence                                                               |

Personal memory may shape an answer but is never presented as company evidence, which avoids a common agent failure: mixing what a user said earlier with what the organisation can prove. When the user looks at a past day, current personal memory is withheld so later context cannot leak into a historical answer. Letta runs in strict permission mode with a memory-file tool allowlist confined to the employee's memory directory.

## 8 Autonomy and human control

| Tier     | Examples                                                        | Behaviour                                    |
|----------|-----------------------------------------------------------------|----------------------------------------------|
| Auto     | Read-only answers, conflict flags                               | May complete automatically                   |
| Approval | Email, ticket, calendar invite, message, document, hiring draft | Waits for the employee's review              |
| Escalate | Money, discounts, prices, refunds, contracts                    | Needs a named human decision; cannot execute |
| Blocked  | Secrets, prompt injections, disallowed content                  | Withheld from the model; cannot execute      |

**Code, not the model, assigns the tier.** The model proposes an action kind and payload; deterministic policy decides whether it is automatic, needs approval or escalates. Approval is bound to a hash of the exact payload, so editing a draft invalidates the old approval and stale approvals cannot send modified content.

### Zero-credential handoff

SMEs rarely have the SSO and fine-grained access control needed to give an agent safe write access. Kaki therefore holds no write credentials for external systems. An approved action opens **prefilled in the employee's own tools**: Gmail compose, a Google Calendar event (or a downloadable `.ics`), a GitHub issue form. The final "send" is always the employee's click, in their own authenticated session. Recruiting follows the same principle: no candidate search until the criteria are confirmed, candidate judgements default to `unclear` when model output is malformed, and outreach is drafted for review.

## 9 Security and guardrails

- **Session-bound identity:** HMAC-SHA256 signed session cookies (`HttpOnly`, expiry, timing-safe comparison); the chat derives the employee from the session and rejects mismatched IDs.
- **Two-layer sensitive-data gate:** fast pattern rules (labelled passwords and codes, vendor key prefixes, private keys, checksum-validated card numbers, bank details, government IDs), then a **model classifier** that asks, with no tools and no memory, whether the message holds an actual secret value. Blocked messages never reach the assistant or memory. If the classifier is unavailable, the rules still apply and the chat stays up.
- **Prompt-injection resistance:** retrieved text and transcripts are treated as data, not instructions; meeting transcripts also pass a deterministic injection screen before any model call.
- **Citation integrity:** see section 6.
- **Least-capability tools:** core company tools are read-only; state-changing tools load only with their skill and stay subject to workflow checks.

**Prototype boundary.** In the demo company every employee can read every record, so document-level access control is not implemented. Before an external pilot: a production identity provider, secure cookies under HTTPS, per-document authorisation in retrieval, and consistent session checks on every data route.



## 10 Evaluation

We measured Kaki two ways: against **OrgForge's own question set**, an independent benchmark we did not write, and a **supplementary suite** for what OrgForge does not test. Every supplementary case was committed to git before it was run, and no case was changed after its result was seen, except the four noted below where our expected answer was wrong.

### 10.1 OrgForge benchmark

**What we ran.** OrgForge ships 78 questions, built to evaluate agents inside its own harness, which gives them simulator tools and per-person visibility data that are not part of the published dataset. Many questions therefore cannot be answered from the records alone. We kept the **29 questions** whose required evidence exists in the records an employee can see, and report on those. The agent model is Qwen 3.8 27B throughout.

**How it was graded.** Each answer is compared with OrgForge's reference conclusion by a fixed judge model at temperature 0 (agrees / disagrees / inconclusive). A conclusion-level judge was used rather than keyword matching, so a correct answer phrased differently is not penalised.

| Metric             | Result       | Meaning                                                              |
|--------------------|--------------|----------------------------------------------------------------------|
| Accuracy           | 62% (18/29)  | Judged against OrgForge's reference conclusions, on the shipped code |
| Citation integrity | 100% (29/29) | Every cited source was actually retrieved in that run                |
| Evidence recall    | 66%          | Share of the benchmark's evidence records the agent retrieved        |

**Where the misses are.** Most misses are questions of the form *did X happen in response to Y*, where OrgForge's definition differs from a plain reading. For example, it counts an email answered by the account owner as "routed", which Kaki read as "handed to another team". We did not tune Kaki to these definitions.

### 10.2 Supplementary suite

| Capability                                     | Result                                        | Cases, including hard ones                                                                                                                                                                 |
|------------------------------------------------|-----------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Says so when the records don't have the answer | no failures in 12                             | 8 invented subjects ("Project Nimbus", a nonexistent ticket); 4 false premises on real tickets ("Why did Tasha take over ENG-101?" when she never did)                                     |
| "What's on my plate today?"                    | 10/10 days, 60/60 items                       | Includes 4 busy days (8–12 items) asked four different ways                                                                                                                                |
| Personal memory                                | 17/18 checks                                  | Remembers across chats, updates a fact changed twice, survives 5 unrelated questions, stays isolated between employees with look-alike facts, never cited as company evidence              |
| Sensitive data (held-out set)                  | 20/20 blocked<br>0/10 false blocks            | Passwords, one-time codes, tokens, connection strings, keys, cards, bank details and government IDs, in phrasings written after the system was built; no secret reached memory in any test |
| Meeting actions                                | 23/24 actions found<br>100% correct risk tier | 18 transcript cases: 9/9 injections and secrets blocked, 0/44 false blocks, every matched action given the right approval tier                                                             |

Four further hard cases were removed after review because our expected answers were wrong: Kaki correctly found that the tickets had been completed through merged pull requests.

### 10.3 Sensitive-data protection

The gate was tested on a held-out set of 20 secrets and 10 look-alike work messages, written after the system was built and never used to tune it. The secrets included passwords typed casually ("the staging login is admin / Spr1ngT1me#4"), one-time codes, session tokens, database connection strings with embedded passwords,

private keys, card numbers, bank details and government IDs. The look-alikes mention the same topics without a secret ("Do we mask SSNs in the export feature?"). Result: **20/20 secrets blocked, 0/10 ordinary messages blocked**, and no secret reached personal memory in any test.

#### 10.4 Automated tests

More than 900 automated tests run on every change, and TypeScript compiles cleanly under `tsc --noEmit`. They cover identity and user isolation, citations, memory behaviour, the sensitive-data gate, meeting approvals, recruiting confirmation and browser behaviour.

---

## 11 Deployment and scalability

Kaki runs as one Node.js service beside PostgreSQL 16 with pgvector (Docker Compose, persistent volume, readiness check) and a Letta server. Optional services (Cognee, speech, Google, people search) switch on only when configured, so the core product runs with just a database and a model endpoint.

**Why it is feasible.** One service coordinates identity, retrieval, models, memory and workflows; PostgreSQL holds evidence, vectors, conversations and meeting state; models sit behind explicit adapters; semantic search degrades to keyword search; and external actions are browser handoffs, avoiding per-integration credentials.

**Scaling path.** A pilot can scale vertically with PostgreSQL and bounded model concurrency. Production needs durable shared queues for per-employee memory updates, coordinated streaming and meeting state across instances, tenant- and document-level authorisation, migration bookkeeping, and per-tenant cost accounting. The main variable costs are generation, embeddings, people search and speech.

---

## 12 Success metrics and demo

| Outcome             | KPI                                     | Now              | Pilot target                               |
|---------------------|-----------------------------------------|------------------|--------------------------------------------|
| Trustworthy answers | Citation integrity                      | 100%             | 100%                                       |
| Correct answers     | Accuracy on answerable questions        | 62% (OrgForge)   | ≥ 80% on the pilot company's own questions |
| Fast answers        | Time to first useful text               | (pilot baseline) | < 3 s                                      |
| Safe automation     | External sends without employee click   | 0 by design      | 0                                          |
| No secret leakage   | Held-out secrets blocked / false blocks | 20/20, 0/10      | ≥ 95%, ≤ 2%                                |
| Less follow-up work | Commitment → approved draft time        | (pilot)          | –50% vs manual                             |

### Demo narrative

1. **Ask:** a question spanning a ticket, a meeting and a policy; Kaki searches, follows links and answers with citations.
2. **Inspect:** open the source cards and the evidence graph.
3. **Remember:** state a working fact, then in a new chat ask something that depends on it; it is used as context, not cited.
4. **Protect:** paste a password; it is blocked before any model sees it.
5. **Act safely:** a meeting commitment becomes a draft; edit it (the old approval is invalidated), approve, and it opens in Gmail for the employee to send.
6. **Escalate:** a discount commitment is routed to a named approver and cannot execute.

## 13 Roadmap

| Phase                                    | Focus                                                                                                                                                                                                                                      | Outcome                                                                                  |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|
| <b>1. Pilot</b><br>0–3 months            | Read connectors for a real SME's Slack, Google Workspace and Jira; single sign-on and per-document permissions in retrieval; the OrgForge and supplementary suites run on every change, alongside questions from the pilot company itself. | Kaki answering from one company's live records, with measured time saved per employee.   |
| <b>2. Team rollout</b><br>3–6 months     | Managed memory and durable background queues for many concurrent employees; streamed first responses within seconds; employees can view and edit what Kaki remembers about them.                                                           | Daily use across a whole team, with per-tenant cost and latency targets.                 |
| <b>3. Trusted actions</b><br>6–12 months | Delegated write access (e.g. creating a Jira ticket directly) for action types a company has approved, extending the same tiered policy and payload-hash approval.                                                                         | Fewer clicks for routine follow-ups, with humans still approving anything consequential. |
| <b>4. More SME functions</b>             | Customer support, finance operations and onboarding, built on the same contract.                                                                                                                                                           | One operating agent for the whole SME.                                                   |

Each phase keeps Kaki's core contract unchanged: retrieve evidence, keep memory separated, prepare typed actions, and keep risk-proportionate human control.

**Claim boundary.** This report describes behaviour implemented and tested in the codebase. Evaluation numbers come from runs recorded in `docs/evaluation/` with the question sets in `eval/`. Pilot targets are goals, not achieved business outcomes.